Fusion Corp

Security Assessment Findings Report

September 17,2023

Table of Contents

Table of Contents 2
Confidentiality Statement 3
Disclaimer 3
Assessment Overview 3
Assessment Components 4
Internal Penetration Test 4
Finding Severity Ratings 5
Risk Factors 5
Likelihood 5
Impact 5
Scope 6
Scope Exclusions 6
Client Allowances 6
Executive Summary 7
Scoping and Time Limitations 7
Testing Summary 7
Tester Notes and Recommendations 8
Key Strengths and Weaknesses 8
Vulnerability Summary & Report Card 9
Internal Penetration Test Findings 9
Technical Findings ..... Error! Bookmark not defined.
Internal Penetration Test Findings ..... Error! Bookmark not defined.

FUSION CORP
BUSINESS CONFIDENTIAL
Copyright © Unid3ntified

Confidentiality Statement

This document is the exclusive property of Fusion Corp and Unidentified. This document contains proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, in any form, requires consent of both Fusion Corp and Und3ntified.

Fusion Corp may share this document with auditors under non-disclosure agreements to demonstrate penetration test requirement compliance.

Disclaimer

A penetration test is considered a snapshot in time. The findings and recommendations reflect the information gathered during the assessment and not any changes or modifications made outside of that period.

Time-limited engagements do not allow for a full evaluation of all security controls. Unid3ntified prioritized the assessment to identify the weakest security controls an attacker would exploit. Unid3ntified recommends conducting similar assessments on an annual basis by internal or third-party assessors to ensure the continued success of the controls.

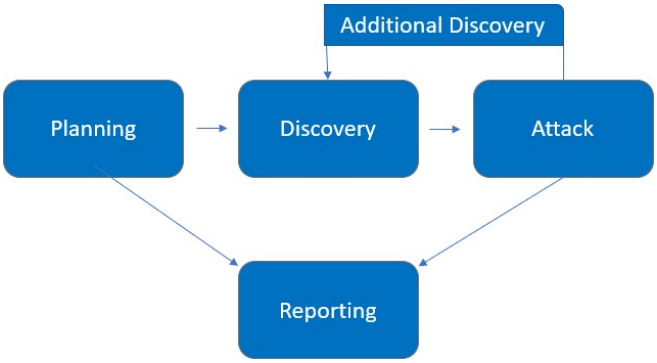
Assessment Overview

From September 16nth 2023 to September 17nth 2023 , Fusion Corp engaged Unid3ntified to evaluate the security posture of its infrastructure compared to current industry best practices that included an external network penetration test. All testing performed is based on the NIST *SP 800-115 Technical Guide to Information Security Testing and Assessment, OWASP Testing Guide (v4), and customized testing frameworks*.

Phases of penetration testing activities include the following:

- Planning – Customer goals are gathered, and rules of engagement obtained.
- Discovery – Perform scanning and enumeration to identify potential vulnerabilities, weak areas, and exploits.
- Attack – Confirm potential vulnerabilities through exploitation and perform additional discovery upon new access.
- Reporting – Document all found vulnerabilities and exploits, failed attempts, and company strengths and weaknesses.

FUSION CORP
BUSINESS CONFIDENTIAL
Copyright © Unid3ntified



Assessment Components

Internal Penetration Test

An internal penetration test emulates the role of an attacker from inside the network. An engineer will scan the network to identify potential host vulnerabilities and perform common and advanced internal network attacks, such as: LLMNR/NBT-NS poisoning and other man- in-the-middle attacks, token impersonation, kerberoasting, pass-the-hash, golden ticket, and more. The engineer will seek to gain access to hosts through lateral movement, compromise domain user and admin accounts, and exfiltrate sensitive data.

FUSION CORP
BUSINESS CONFIDENTIAL
Copyright © Unid3ntified

Finding Severity Ratings

The following table defines levels of severity and corresponding CVSS score range that are used throughout the document to assess vulnerability and risk impact.

Severity	CVSS V3 Score Range	Definition
Critical	9.0-10.0	Exploitation is straightforward and usually results in system-level compromise. It is advised to form a plan of action and patch immediately.
High	7.0-8.9	Exploitation is more difficult but could cause elevated privileges and potentially a loss of data or downtime. It is advised to form a plan of action and patch as soon as possible.
Moderate	4.0-6.9	Vulnerabilities exist but are not exploitable or require extra steps such as social engineering. It is advised to form a plan of action and patch after high-priority issues have been resolved.
Low	0.1-3.9	Vulnerabilities are non-exploitable but would reduce an organization's attack surface. It is advised to form a plan of action and patch during the next maintenance window.
Informational	N/A	No vulnerability exists. Additional information is provided regarding items noticed during testing, strong controls, and additional documentation.

Risk Factors

Risk is measured by two factors: Likelihood and Impact:

Likelihood

Likelihood measures the potential of a vulnerability being exploited. Ratings are given based on the difficulty of the attack, the available tools, attacker skill level, and client environment.

Impact

Impact measures the potential vulnerability's effect on operations, including confidentiality, integrity, and availability of client systems and/or data, reputational harm, and financial loss.

FUSION CORP
BUSINESS CONFIDENTIAL
Copyright © Unid3ntified

Scope

Assessment	Details
Internal Penetration Test	10.10.51.251

Scope Exclusions

Per client request, Unid3ntified did not perform any of the following attacks during testing:

- Denial of Service (DoS)
- Phishing/Social Engineering

All other attacks not specified above were permitted by Fusion Corp.

Client Allowances

Fusion Corp provided Unid3ntified the following allowances:

- Internal access to network via vpn and port allowances

FUSION CORP
BUSINESS CONFIDENTIAL
Copyright © Unid3ntified

Executive Summary

Unid3ntified evaluated Fusion Corp's internal security posture through penetration testing from September 16nth 2023 to September 17nth 2023. The following sections provide a high-level overview of vulnerabilities discovered, successful and unsuccessful attempts, and strengths and weaknesses.

Scoping and Time Limitations

Scoping during the engagement did not permit denial of service or social engineering across all testing components.

Time limitations were in place for testing. Internal network penetration testing was permitted for two(2) business days.

Testing Summary

The network assessment evaluated Fusion Corp's internal network security posture. From an internal perspective, the Unid3ntified team performed vulnerability scanning against all IPs provided by Fusion Corp to evaluate the overall patching health of the network. The team also performed common Active Directory based attacks, such as Link-Local Multicast Name Resolution (LLMNR) Poisoning, SMB relaying, IPv6 man-in-the-middle relaying, and Kerberoasting. Beyond vulnerability scanning and Active Directory attacks, the Unid3ntified evaluated other potential risks, such as open file shares, default credentials on servers/devices, and sensitive information disclosure to gain a complete picture of the network's security posture.

The Unid3ntified team was able to retrieve a Ticket Granting Ticket(TGT) on behalf of the victim account who do not have "Do not require Kerberos preauthentication" set. From that the TGT retrieved was cracked and the password for that victim account was retrieved.
Unid3ntified team was able to authenticate using the discovered username and password, and subsequently, it enumerated user accounts within the "fusion.corp" domain and as a result we were able to discover another victim account which had password in the description. Unid3ntified team was then able to use the newly discovered credentials to dump the administrator 's hash and log into the domain controller.

The remainder of the findings were high, moderate, low, or informational. For further information on findings, please review the Technical Findings section.

FUSION CORP
BUSINESS CONFIDENTIAL
Copyright © Unid3ntified

Tester Notes and Recommendations

Testing results of the Fusion Corp network are indicative of an organization undergoing its first penetration test, which is the case here. Many of the findings discovered are vulnerabilities within Active Directory that come enabled by default, such as Kerberoasting.

During testing, one constant stood out: a weak password policy. The weak password policy led to the initial compromise of accounts and is usually one of the first footholds an attacker attempts to use in a network. The presence of a weak password policy is backed up by the evidence of our testing team cracking user account password from the TGT.

We recommended that Fusion Corp re-evaluates their current password policy and considers a policy of 15 characters or more for their regular user accounts and 30 characters or more for their Domain Administrator accounts. We also recommend that Fusion Corp explore password blacklisting and will be supplying a list of cracked user passwords for the team to evaluate. Finally, a Privilege Access Management solution should be considered.

Overall, the Fusion Corp network performed as expected for a first-time penetration test. We recommend that the Fusion Corp team thoroughly review the recommendations made in this report, patch the findings, and re-test annually to improve their overall internal security posture.

Key Strengths and Weaknesses

The following identifies the key strengths identified during the assessment:

1. SMB signing is enabled and required.

The following identifies the key weaknesses identified during the assessment:

1. Password policy was found to be insufficient.
2. Anonymous and guest login on multiple services such as smb was enabled.
3. “Do Not Require Kerberos Preauthentication” was not implemented for domain accounts.

FUSION CORP
BUSINESS CONFIDENTIAL
Copyright © Unid3ntified

Vulnerability Summary & Report Card

The following tables illustrate the vulnerabilities found by impact and recommended remediations:

Internal Penetration Test Findings

13	5	6	0	1
Critical	High	Moderate	Low	Informational

Finding	Severity	Recommendation
Internal Penetration Test		
IPT-001: Insufficient Password Complexity	Critical	Implement CIS Benchmark password requirements / PAM solution.
IPT-002: No Preauthentication – Kerberoasting	High	Retrieve Ticket Granting Ticket for domain users
IPT-003: No Limit Access to Critical Files	High	Grant Privileged access only to domain users
IPT-004: Clear Text Password in Account Description	Moderate	Do not put passwords in account description
IPT-005: Employee Data Exposed to the Public	Low	Do not expose employee data to the internet.

FUSION CORP
BUSINESS CONFIDENTIAL
Copyright © Unid3ntified

Technical Findings

Internal Penetration Test Findings

Finding IPT-001: Insufficient Password Complexity (Critical)

Description:	Unid3ntified dumped Ticket Granting Ticket(TGT) from the domain controller and proceeded to attempt common password guessing attacks against all users.
Risk:	Likelihood: High - Simple passwords are susceptible to password cracking attacks. Encryption provides some protection, but dictionary attacks base on common word lists often crack weak passwords. Impact: Very High - Domain admin accounts with weak passwords could lead to an adversary critically impacting Fusion Corp ability to operate.
System:	All
Tools Used:	Hashcat
References:	NIST SP800-53 IA-5(1) - Authenticator Management https://www.cisecurity.org/white-papers/cis-password-policy-guide/

Evidence

Figure 7: Excerpt of cracked domain hashes

Remediation

Implement CIS Benchmark password requirements / PAM solution. Unid3ntified recommends that Fusion Corp enforce industry best practices around password complexity and management. A password filter to prevent users from using common and easily guessable passwords is also recommended. Additionally, Unid3ntified recommends that Fusion Corp enforce stricter password requirements for Domain Administrator and other sensitive accounts.

FUSION CORP
BUSINESS CONFIDENTIAL
Copyright © Unid3ntified

Finding IPT-002: No PreAuthentication– Kerberoasting (High)

Description:	Unid3ntified retrieved all NPUsers from the Fusion Corp domain controller using usernames files on the company website. Retrieving these user TGT permitted Unid3ntified to crack 1 account password.
Risk:	Likelihood: High – Any account joined to the domain can request user SPNs. Impact: High – Using NPUsers, it is possible to retrieve sensitive account password hashes and crack them offline.
Tools Used:	Impacket, Hashcat
References:	Kerberoasting details: https://adsecurity.org/?p=2293 Group Managed Service Accounts Overview

Evidence

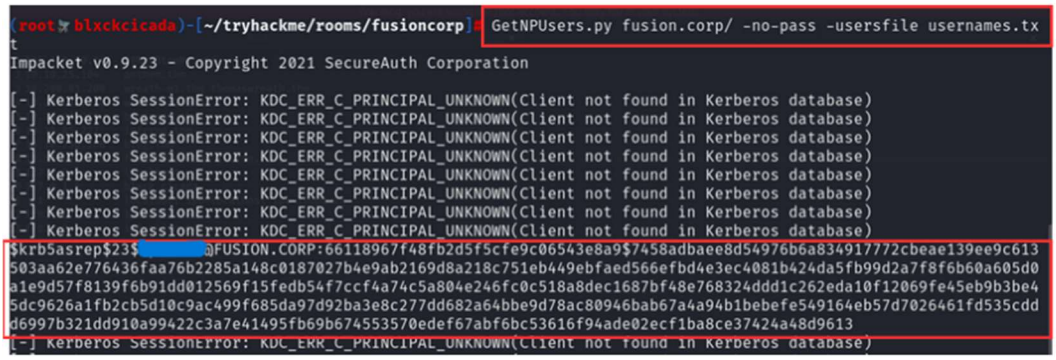


Figure 14: TGT discovery

Remediation

Implement "Do Not Require Kerberos Preauthentication" for users who do not require Kerberos preauthentication (which is typically used for services accounts), enable the "Do not require Kerberos preauthentication" setting where appropriate. This should be done for accounts that truly need this setting, and it should not be applied to regular user accounts.

FUSION CORP
BUSINESS CONFIDENTIAL
Copyright © Unid3ntified

Finding IPT-003: No Limit Access to Critical Files (High)

Description:	Fusion Corp domain user was granted SeBackupPrivilege which allows the user to read critical files.
Risk:	Likelihood: High – sam and system files can be dumped and user hashes can be extracted Impact: Moderate – Attackers can use the hashes extracted to pass the hash and gain access to local administrators or user domain accounts
System:	10.x.x.x
Tools Used:	Powershell,impacket
References:	NIST SP800-53r4 AC-6(3) - Least Privilege NIST SP800-53 r4 SC-4 - Information in Shared Resources

Evidence

```
*Evil-WinRM* PS C:\Users\[redacted]\Documents> Import-Module .\SeBackupPrivilegeCmdLets.dll
*Evil-WinRM* PS C:\Users\[redacted]\Documents> Import-Module .\SeBackupPrivilegeUtils.dll
*Evil-WinRM* PS C:\Users\[redacted]\Documents> Copy-FileSebackupPrivilege E:\Windows\NTDS\ntds.dit ntds.dit
*Evil-WinRM* PS C:\Users\[redacted]\Documents> reg save hklm\system system
The operation completed successfully.
```

Figure 19: clear text password in account description

```
┌──(root💀 blxckcicada)-[~/tryhackme/rooms/fusioncorp]
└─# secretsdump.py -sam sam -system system local
Impacket v0.9.23 - Copyright 2021 SecureAuth Corporation

[*] Target system bootKey: 0xeafd8ccae4277851fc8684b967747318
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:[redacted]:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[-] SAM hashes extraction for user WDAGUtilityAccount failed. The account doesn't have hash information.
[*] Cleaning up ...
```

Remediation

Restrict access to sensitive files like the SAM and SYSTEM files to only authorized users and processes. Employ strict access controls, and regularly review and update file permissions to ensure that only necessary personnel have access to these critical system files.

FUSION CORP
BUSINESS CONFIDENTIAL
Copyright © Unid3ntified

Finding IPT-004: Clear Text Password in Account Description (Moderate)

Description:	Fusion Corp domain user exposed clear text password in the account description
Risk:	Likelihood: Moderate – Adversaries will discover these passwords Impact: Moderate – Attackers can leverage this account to gain access into the privilege's domain user account.
System:	10.x.x.x
Tools Used:	crackmapexec
References:	NIST SP800-53r4 AC-6(3) - Least Privilege NIST SP800-53 r4 SC-4 - Information in Shared Resources

Evidence

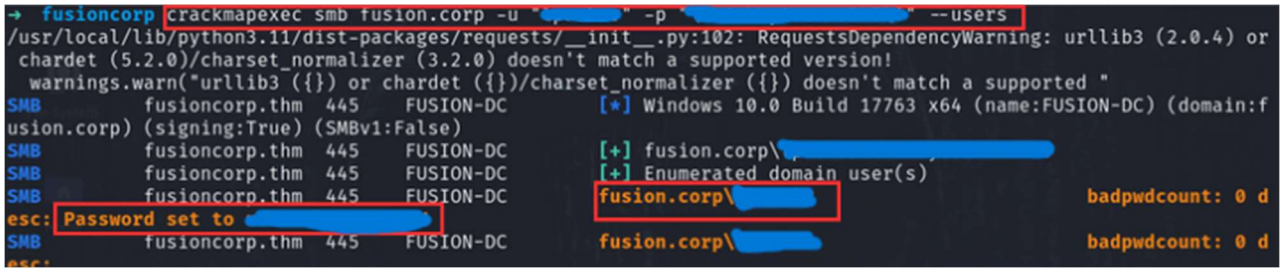


Figure 19: clear text password in account description

Remediation

Do not allow domain users to save clear text passwords in their account's description.

FUSION CORP
BUSINESS CONFIDENTIAL
Copyright © Unid3ntified

Finding IPT-005: Employee Data Exposed to the Public (Low)

Description:	Fusion Corp exposed employee personal data to the internet. Employee names and usernames were saved in a spreadsheet on the company website.
Risk:	Likelihood: Low – Employee usernames can be used to grab Ticket Granting Ticket and to perform kerberoasting. Impact: Low – An attacker can leverage the TGT to crack them and get user access.
Tools Used:	ffuf
References:	NIST SP800-53 r4 SI-2 - Flaw Remediation

Evidence

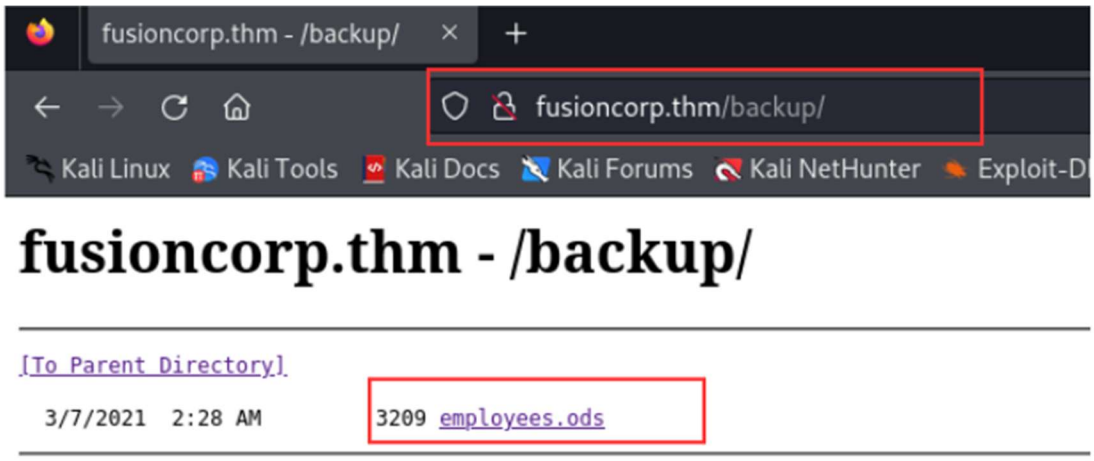
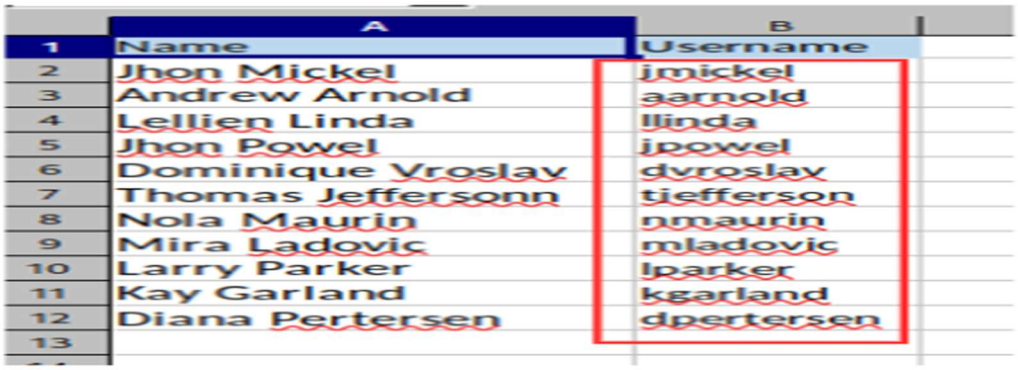


Figure 20: exposed employee data



	A	B
1	Name	Username
2	Jhon Mickel	jmickel
3	Andrew Arnold	aarnold
4	Lellien Linda	llinda
5	Jhon Powel	jpowel
6	Dominique Vroslav	dvroslav
7	Thomas Jeffersonn	tjefferson
8	Nola Maurin	nmaurin
9	Mira Ladovic	mladovic
10	Larry Parker	lparker
11	Kay Garland	kgarland
12	Diana Pertersen	dpertersen
13		

Figure 21: exposed employee data in spreadsheet

FUSION CORP
BUSINESS CONFIDENTIAL
Copyright © Unid3ntified

Remediation

Do not publish employee personal and sensitive information, such as usernames, on the website or any public-facing platform. Ensure that sensitive data is properly secured and access-controlled, following industry best practices and compliance standards.

FUSION CORP
BUSINESS CONFIDENTIAL
Copyright © Unid3ntified

Last Page

BUSINESS CONFIDENTIAL
Copyright © Unid3ntified